

Relatively Risky

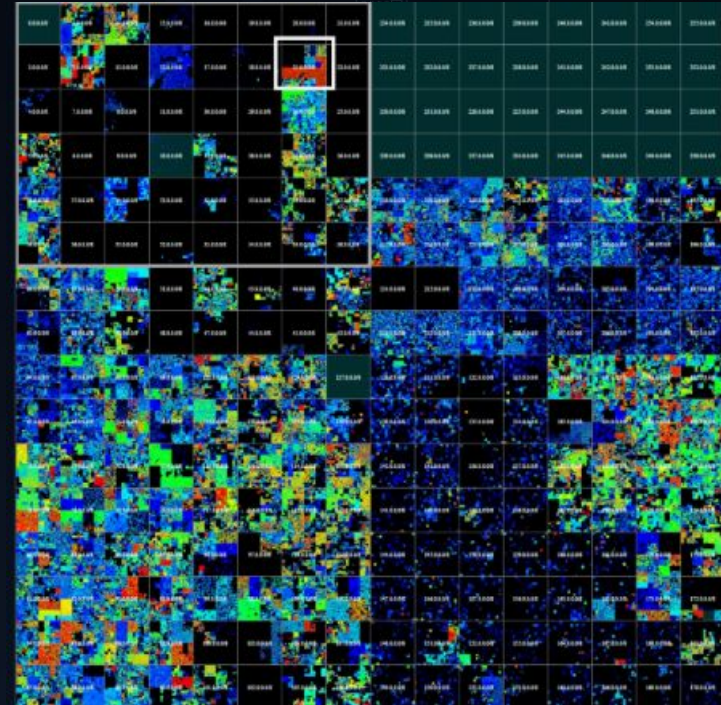
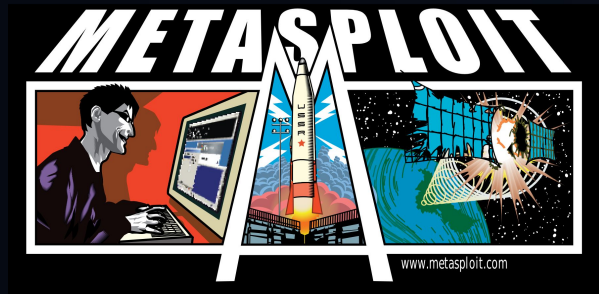
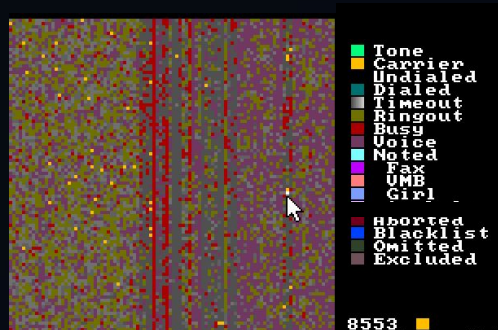
Identifying Exposures at Scale
with BloodHound Open Graph

HD Moore



Simpler Times In Network Pivoting

ATTACKERS ALSO LIKE TO THINK IN LISTS AND THAT USED TO BE GOOD ENOUGH



Network Security is 99% Segmentation

IF YOU CAN'T FIX, YOU PUT IT IN THE CORNER, HOPEFULLY BY ITSELF



End-of-Life Products

Virtual machines and network devices that rot in place and can't easily upgrade



Third-Party Vendor Systems

You don't own it, you can't touch it, but you can't get rid of it



Jenky Old Network Appliances

This 1U pizza box is the last remnant of a previous organization, running countless mysterious jobs

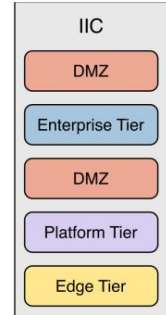
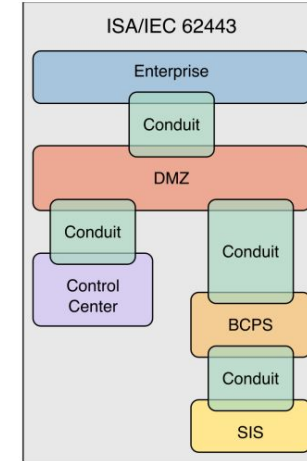
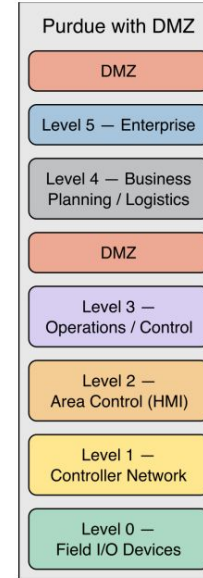
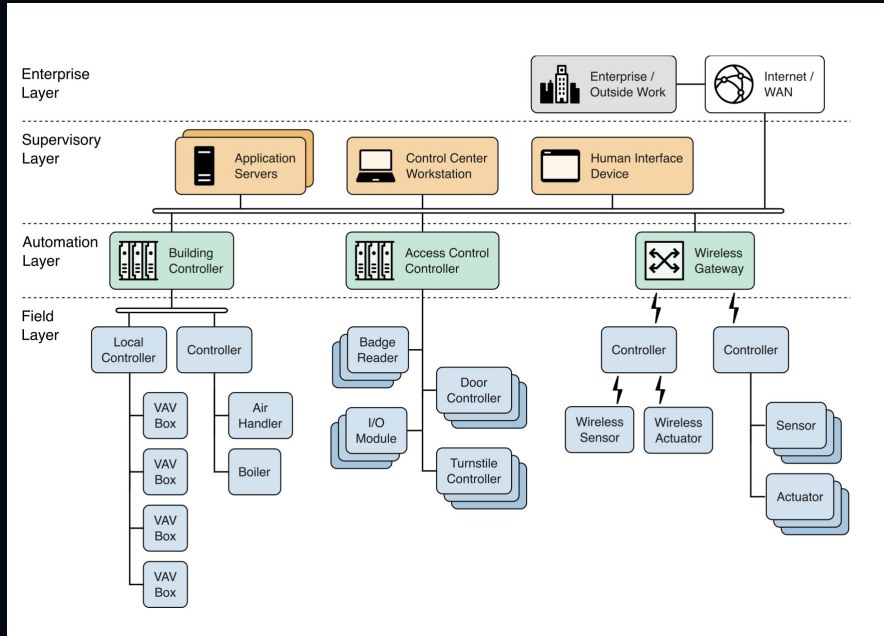


OT, IoT, BMS, OOB, IoMT

You actually need it, but you can't install an endpoint agent, you can't patch it, and it might have a cellular connection

OT: NIST 800-82 Reference Architecture

PICK ANY ARCHITECTURE, BUT YOUR CONTROL SYSTEMS ARE ONLY ONE STEP AWAY FROM DOOM



Purdue Model for ICS Security: Layers and Zones of Defense

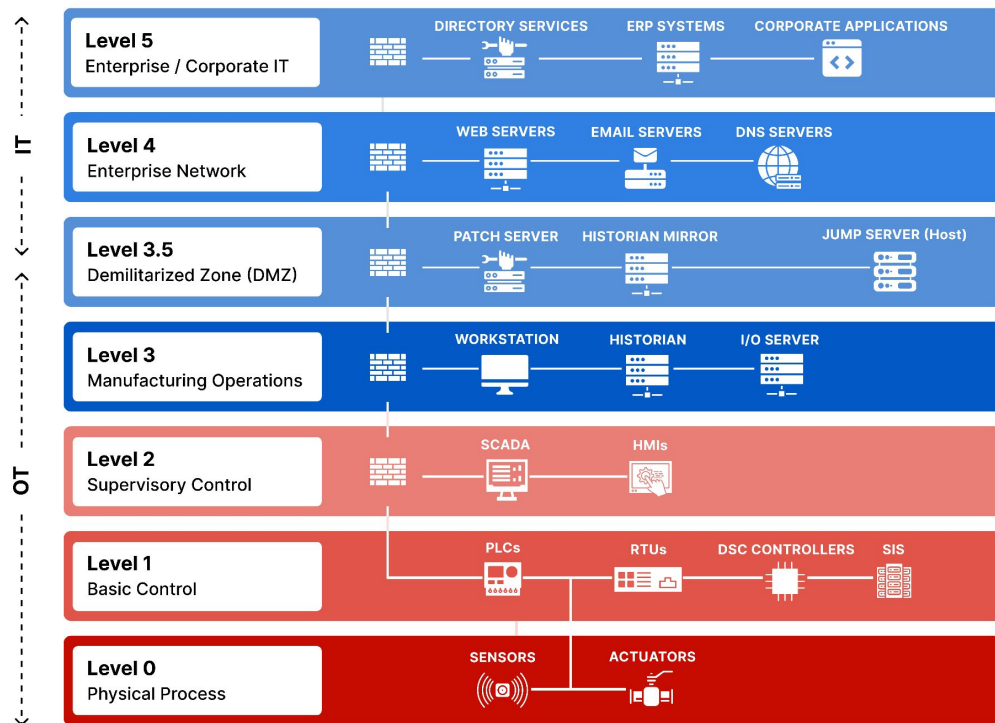


Diagram from Fortinet.com



NIST Likes Firewalls

“Firewalls are commonly used to support network isolation and employed as boundary protection devices to control connections and information flows between network segments.”

*“Firewalls are very flexible isolation devices and typically constitute the **primary mechanism** for protecting OT devices”*

Purdue Model for ICS Security: Layers and Zones of Defense

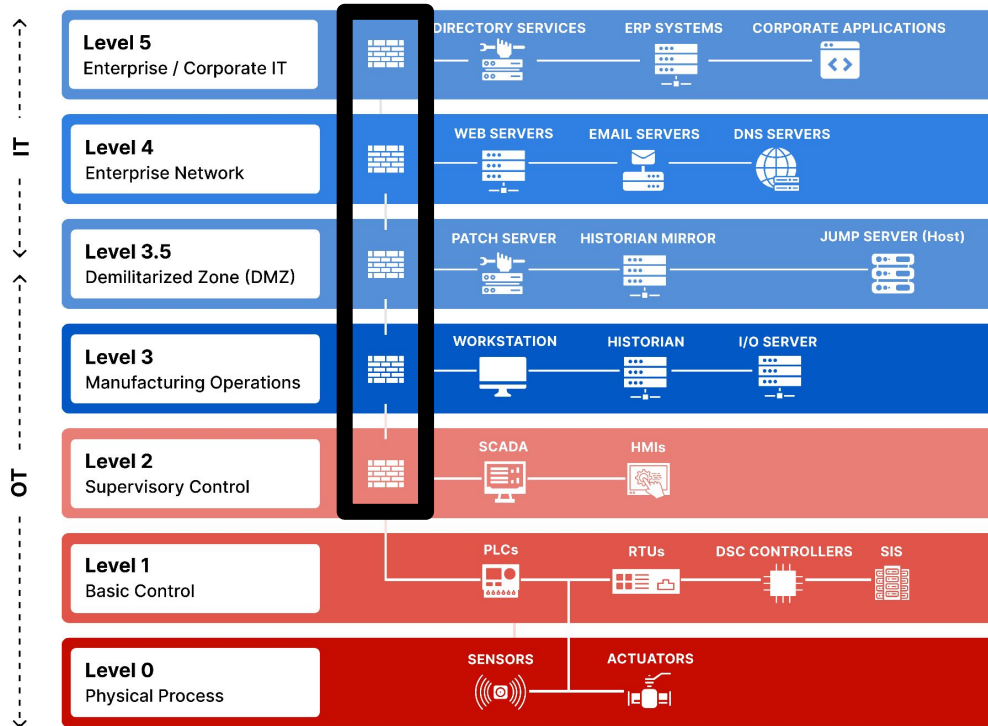


Diagram from Fortinet.com

< [Alert](#)

ALERT

Fortinet Releases Guidance to Address Ongoing Exploitation of Authentication Bypass Vulnerability CVE-2026-24858

Release Date: January 28, 2026

Newly disclosed vulnerability [Common Vulnerabilities and Exposures \(CVE\)-2026-24858](#)  [[Common Weakness Enumeration \(CWE\)-288: Authentication Bypass Using an Alternate Path or Channel](#) ] allows malicious actors with a FortiCloud account and a registered device to log in to separate devices registered to other users in FortiOS, FortiManager, FortiWeb, FortiProxy, and FortiAnalyzer, if FortiCloud single sign on (SSO) is enabled on devices.¹

Users are vulnerable to [CVE-2026-24858](#)  even if they updated Fortinet devices to address previously disclosed FortiCloud SSO bypass vulnerabilities [CVE-2025-59718](#)  and [CVE-2025-59719](#)  [[CWE-347: Improper Verification of Cryptographic](#)



Hackers Like Firewalls Too

PALO ALTO NETWORKS FINALLY DETHRONED BY SHAREPOINT IN 2025 AS INITIAL ACCESS VECTOR

Most Frequently Exploited Vulnerabilities

Among the Mandiant incident response investigations performed in 2024, the most frequently exploited vulnerabilities affected security devices, which are, due to their function, typically placed at the edge of the network. Three of the four vulnerabilities were first exploited as zero-days. While a broad selection of threat actors have recently targeted edge devices, Mandiant also specifically noted an increase³ in targeting from Russian⁴ and Chinese⁵ cyber espionage actors.

Most Frequently Exploited Vulnerabilities



Segmentation: Difficult & Expensive

ALL MODERN (AND NO SO MODERN) COMPUTING IS HYPER NETWORKED



```
~ $ ifconfig | egrep '^[a-z]'
lo0: flags=0049<UP,LOOPBACK,RUNNING,MULTICAST> mtu 16384
gif0: flags=0010<POINTOPOINT,MULTICAST> mtu 1200
stf0: flags=0<> mtu 1200
anp12: flags=0063<UP,BROADCAST,SMART,RUNNING,SIMPLEX,MULTICAST> mtu 1500
anp10: flags=0063<UP,BROADCAST,SMART,RUNNING,SIMPLEX,MULTICAST> mtu 1500
anp11: flags=0063<UP,BROADCAST,SMART,RUNNING,SIMPLEX,MULTICAST> mtu 1500
en4: flags=0063<UP,BROADCAST,SMART,RUNNING,SIMPLEX,MULTICAST> mtu 1500
en5: flags=0063<UP,BROADCAST,SMART,RUNNING,SIMPLEX,MULTICAST> mtu 1500
en6: flags=0063<UP,BROADCAST,SMART,RUNNING,SIMPLEX,MULTICAST> mtu 1500
en1: flags=0063<UP,BROADCAST,SMART,RUNNING,PROMISC,SIMPLEX,MULTICAST> mtu 1500
en2: flags=0063<UP,BROADCAST,SMART,RUNNING,PROMISC,SIMPLEX,MULTICAST> mtu 1500
en3: flags=0063<UP,BROADCAST,SMART,RUNNING,PROMISC,SIMPLEX,MULTICAST> mtu 1500
bridge0: flags=0063<UP,BROADCAST,SMART,RUNNING,SIMPLEX,MULTICAST> mtu 1500
utun0: flags=0051<UP,POINTOPOINT,RUNNING,MULTICAST> mtu 1500
ap1: flags=0063<UP,BROADCAST,SMART,RUNNING,SIMPLEX,MULTICAST> mtu 1500
utun1: flags=0051<UP,POINTOPOINT,RUNNING,MULTICAST> mtu 1300
en0: flags=0063<UP,BROADCAST,SMART,RUNNING,SIMPLEX,MULTICAST> mtu 1500
aud10: flags=0063<UP,BROADCAST,SMART,RUNNING,SIMPLEX,MULTICAST> mtu 1500
llw0: flags=0063<UP,BROADCAST,SMART,RUNNING,SIMPLEX,MULTICAST> mtu 1500
utun2: flags=0051<UP,POINTOPOINT,RUNNING,MULTICAST> mtu 2000
utun3: flags=0051<UP,POINTOPOINT,RUNNING,MULTICAST> mtu 1000
utun5: flags=0051<UP,POINTOPOINT,RUNNING,MULTICAST> mtu 1300
utun6: flags=0051<UP,POINTOPOINT,RUNNING,MULTICAST> mtu 1300
utun7: flags=0051<UP,POINTOPOINT,RUNNING,MULTICAST> mtu 1300
utun8: flags=0051<UP,POINTOPOINT,RUNNING,MULTICAST> mtu 1300
utun4: flags=0051<UP,POINTOPOINT,RUNNING,MULTICAST> mtu 1200
vmenet2: flags=0063<UP,BROADCAST,SMART,RUNNING,PROMISC,SIMPLEX,MULTICAST> mtu 1500
bridge102: flags=0063<UP,BROADCAST,SMART,RUNNING,ALLMULTI,SIMPLEX,MULTICAST> mtu 1500
vmenet0: flags=0063<UP,BROADCAST,SMART,RUNNING,PROMISC,SIMPLEX,MULTICAST> mtu 1500
bridge100: flags=0063<UP,BROADCAST,SMART,RUNNING,ALLMULTI,SIMPLEX,MULTICAST> mtu 1500
vmenet1: flags=0063<UP,BROADCAST,SMART,RUNNING,PROMISC,SIMPLEX,MULTICAST> mtu 1500
bridge101: flags=0063<UP,BROADCAST,SMART,RUNNING,ALLMULTI,SIMPLEX,MULTICAST> mtu 1500
utun9: flags=0050<POINTOPOINT,RUNNING,MULTICAST> mtu 1200
```


Air Gaps Hate This One Weird Trick

SEGMENTATION ISN'T REAL AND CAN'T ~HURT~STOP YOU



Why Asset Relationships Matter

THE FUN VULNS DON'T REQUIRE EXPLOITS OR AUTHENTICATION — JUST ACCESS

 REAL EXAMPLE

PCI CDE Segmentation Bust

Printer on corp VLAN has second NIC on CDE VLAN. IP forwarding enabled. Shared SSH key with CDE jump host.

 REAL EXAMPLE

OT Segmentation Bust

BACnet thermostat on internet. Router behind it bridges to MS/TP bus. 40+ HVAC controllers accessible. Boilers, pumps, fire suppression.



In BloodHound identity terms:

These are the equivalent of discovering an unintended trust path — a GenericAll that nobody configured deliberately. The printer didn't mean to be a bridge. The thermostat didn't mean to expose the building. But the graph shows the truth.

You Already Think in Graphs

SEGMENTATION ISN'T REAL — AND IT CAN'T HURT YOU

BloodHound Identity

- User → Group → Domain Admin
- GenericAll on OU → child objects
- Kerberoastable SPN → hash → creds
- Unconstrained delegation → TGT
- Cross-forest trust → SID history
- AD: GenericAll on GPO

Asset Relationships

- Switch → Port → VLAN → Subnet
- BMC → MANAGES → Host → MANAGES BMC
- Gateway → Backplane → PLC
- Crypto keys shared across systems
- Multi-homed hosts bridge networks
- Net: BMC MANAGES host (full control)

Asking Nicely Works Well

SOMETIMES IT IS THAT EASY

SNMP (Even Unauthenticated)

Every device on the segment, including those that don't respond to port scans

NetBIOS 2-Packet Leak

Reveals secondary IPv4 addresses. Critical for finding multi-homed hosts

mDNS & AirPlay

Amazingly detailed data: MAC, IP, device color. Apple devices expose everything

DCE/RPC OxidResolver

Returns full hostname + all IPv4/IPv6 addresses. EPM works in a pinch

TLS Certificates

Self-signed certs on appliances leak their management IP even across interfaces

Windows HMI (XP-era)

Windows disables 137/UDP by default — but HMIs run XP. DCE/RPC still exposed

A System In More Than One Place

ANY UNIQUE IDENTIFIER FOR A RUNNING SYSTEM BECOMES A BRIDGE DETECTION TOOL

SNMPv3 Engine ID

Mostly unique per device. Confirm with counter review.

IPMI RAKP GUID

No auth needed. Correlates BMC to host; other bits identify the BMC itself.

SMB2 Server GUID

From NEGOTIATE response, pre-auth. Correlates host across interfaces (resets on reboot).

NetBIOS UDP

Responds with local name (unique per segment) and MAC address.

SSH Host Key FP

Exchanged before auth. Shared key = shared identity or credential reuse.

NTLMSSP + DCERPC

Leaks internal IPs, domain names, timestamps, and OS version.

TLS Cert FP

Shared certs often point to same system — especially RDP. SANs useful too.

Gateways: Seeing Behind Devices

OFF-THE-SHELF TOOLS BARELY SCRATCH THE SURFACE

SNMP MAC + ARP

Every device on the segment, including those that don't respond to scans

BACnet Router

Register as foreign router, send Who-Is → all devices on MS/TP bus. Reach entire building network.

EtherNet/IP CIP

ListIdentity → gateway. Route path walks backplane slots. Bonus: IP relaying trick.

Modbus TCP

Gateway bridges RS-485. Unit ID sweep, FC43 MEI for vendor/product. Also read various registers.

KNXnet/IP

Tunnel to TP1 bus. Listen for broadcast or slowly scan for specific slot IDs.

The Data Challenge

IT'S SCATTERED, FINICKY, AND THE TOOLS AREN'T GOOD AT IT



No Single Credential

Segmentation leaks come from unauthenticated scans, pcaps, SNMP community strings, and protocol handshakes. One credential isn't enough on its own.



Same Device, Many Faces

A host appears as an IP, a MAC, an SSH key, an SMB GUID, an SNMPv3 engine ID, a TLS cert. Correlate them or you're counting the same box twice.



Gateways Hide Devices

An EtherNet/IP gateway looks like one IP — but behind it are 16 PLC slots. A BACnet router hides 350 building controls. Protocol-specific enumeration required.



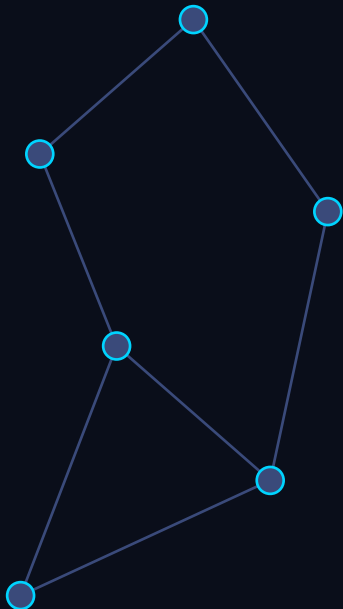
No Standard Collector

SharpHound collects AD in one tool. For network data: snmpwalk + nmap + ipmitool + ssh-keyscan + custom OT walkers. No unified collector exists yet.

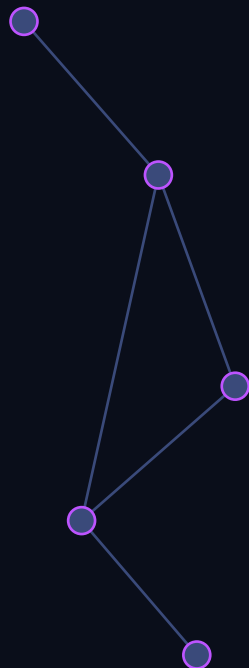
runZeroHound Updates & Demo!



<https://github.com/runZeroInc/runZeroHound>



DEMO



Identity Is Only Part of It

BloodHound maps the identity plane beautifully. But attackers pivot through OOB channels, bridge networks, and protocol gateways to reach physical infrastructure. Overlay network graphs on identity graphs and go twice as far!

Next Steps

1 Collect network data you already have

You're already running SNMP, traceroute, SSH/TLS scans. Parse the output into structured edges.

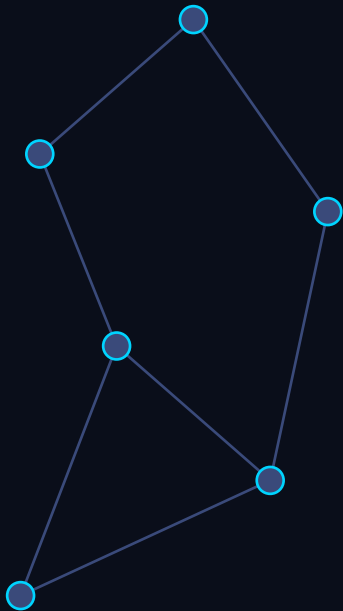
2 Build the deeper collection tools

Walk OT protocols and exploit network leaks to get better fidelity.

3 Play with the *Hounds (Network Hound, Data Hound, runZeroHound, etc)

Smooshes security tool output into Open Hound graph data.

The graph doesn't end at Domain Admin.



Q & A

Thank you for your time!

x /at/ hdm.io

